Conditional Access Design

Zero Trust sign-in policy for the HVMC Entra ID tenant · Hands-on Step 6

Prepared by Sabitha S Karanavar · 20 October 2026 · Version 1.0 · Status: design approved for report-only deployment

1. Purpose and current state

Conditional Access (CA) decides, at every sign-in, whether access is allowed, needs more proof (MFA, a managed device) or is blocked, based on who is signing in, to which app, from where and with what risk. This document designs the CA policy set for HVMC on top of the identity work already done: department managers and employee IDs (Step 1), RBAC v2 groups (Step 2), ten enterprise applications (Step 3), joiner/mover/leaver (Step 4) and access review HVMC-AR-2026-Q4 (Step 5).

Licence	Entra ID Free — CA requires P1; risk-based policies require P2. Design only for now; the 13 policies are generated as deployable report-only Graph files (`policies/`) and `deploy_ca.py` refuses to apply without a licence.
Current protection	**Security defaults ON** (confirmed: a device-code sign-in was blocked with AADSTS530035 on 14 Oct 2026): MFA registration for all, MFA for admins, legacy authentication blocked. Good baseline, but all-or-nothing: no per-app, per-device or per-group rules.
Existing CA policies	0
Related open settings	Users can register apps and consent to app permissions; anyone can invite guests (risk R08) — see section 7.

2. Design principles

- **Persona-based:** policies target personas (everyone, administrators, clinical users of ePHI apps, contractors), not individuals.
- **Naming:** `CA###-Persona-Apps-Control`, so the policy list reads as documentation.
- **Break-glass excluded from every policy:** two cloud-only emergency accounts with FIDO2 keys in group `SG-CA-Exclude-BreakGlass`, monitored by a Sentinel alert on any use (this also closes the open R04 action from the access review).
- **Report-only first:** every policy starts in `enabledForReportingButNotEnforced`; nobody is locked out by a design mistake.
- **Least privilege continues at sign-in:** RBAC decides *what* a person may use; CA decides *under which conditions*.

3. Policy set

ID	Policy	Users	Apps	Condition	Grant	Session	Licence	Risks
CA001	CA001-Global-AllApps-BlockLegacyAuthentication	All users	All	Legacy clients	Block	—	P1	R12
CA002	CA002-Admins-AllApps-RequirePhishingResistantMFA	8 admin roles	All	Any	Phishing-resistant MFA	Re-auth 4 h	P1	R04, R12
CA003	CA003-Global-AllApps-RequireMFA	All users	All	Any	MFA	—	P1	R12, R06
CA004	CA004-Global-AzureManagement-RequireMFA	All users	Azure management	Any	MFA	—	P1	R02, R15
CA005	CA005-Global-ePHIApps-RequireMFAandManagedDevice	All users	Electronic Health Record, Pharmacy Management System, Laboratory Information System, EHR-Simulated	Any	MFA AND Compliant device	Re-auth 8 h	P1 + Intune	R02, R13
CA006	CA006-Global-ePHIApps-NoPersistentBrowserOnUnmanaged	All users	Electronic Health Record, Pharmacy Management System, Laboratory Information System, EHR-Simulated	Non-compliant device	— (session only)	Re-auth 1 h, No persistent browser	P1	R02
CA007	CA007-Contractors-AllExceptAssigned-Block	SG-Contractors-ITAdmin-Limited, SG-Contractors-VPN-Read	All; except IT Administration Console, VPN Portal	Any	Block	—	P1	R06
CA008	CA008-Contractors-AllApps-MFAEverySession	SG-Contractors-ITAdmin-Limited, SG-Contractors-VPN-Read	All	Any	MFA	Every sign-in, No persistent browser	P1	R06
CA009	CA009-Global-AllApps-BlockOutsideAllowedCountries	All users	All	Outside US	Block	—	P1	R12
CA010	CA010-Global-AllApps-BlockDeviceCodeAndAuthTransfer	All users	All	Device-code / auth transfer	Block	—	P1	R12
CA011	CA011-Global-SecurityInfoRegistration-RequireUSLocationOrMFA	All users	User action: register security info	Outside US	MFA	—	P1	R12
CA012	CA012-Global-AllApps-HighUserRisk-SecurePasswordChange	All users	All	User risk high	MFA AND Password change	Every sign-in	P2	R12
CA013	CA013-Global-AllApps-MediumHighSignInRisk-RequireMFA	All users	All	Sign-in risk medium/high	MFA	Every sign-in	P2	R12

Why each policy exists

ID	Persona	Reason
CA001	Everyone	Legacy protocols (IMAP, POP, SMTP AUTH, older Office clients) cannot do MFA and are the main password-spray target.

CA002	Administrators	Admin accounts are the highest-value target; phishing-resistant methods (FIDO2 passkey, Windows Hello) defeat AiTM proxies.
CA003	Everyone	Baseline: every interactive sign-in to any app requires MFA (replaces security defaults when CA is enforced).
CA004	Everyone	Portal, CLI and PowerShell can change the ePHI storage and network; always MFA, even from trusted places.
CA005	Clinical users (EHR, Pharmacy, LIS)	Patient data opens only on a hospital-managed (compliant or hybrid-joined) device with MFA; shift-length session.
CA006	Everyone on unmanaged devices	Defence in depth if CA005 is in report-only during rollout: no 'stay signed in', re-authenticate hourly on non-compliant devices.
CA007	Contractors	Contractors may reach only the apps their contract covers (IT Admin Console - limited, VPN); everything else is blocked.
CA008	Contractors	Contractors re-authenticate with MFA every sign-in and never get a persistent session.
CA009	Everyone	HVMC operates only in the US; sign-ins from other countries are blocked (travel exceptions via a temporary group).
CA010	Everyone	Device-code phishing and cross-device token transfer are current attack techniques; no HVMC workflow needs them.
CA011	Everyone	An attacker with a stolen password must not be able to register their own MFA method.
CA012	Everyone	Leaked-credential or high user risk forces MFA plus a password change before access.
CA013	Everyone	Suspicious sign-ins (anonymous IP, impossible travel, token anomalies) must pass MFA again.

4. Break-glass (emergency access) accounts

Accounts	2 cloud-only accounts on the .onmicrosoft.com domain, Global Administrator, not tied to any person or device
Authentication	FIDO2 security keys held in two separate locked locations (IT Manager, Security Supervisor)
Policy scope	Excluded from every CA policy through `SG-CA-Exclude-BreakGlass`; the group itself is reviewed every quarter
Monitoring	Sentinel analytics rule: any sign-in by a break-glass account raises a High incident and e-mails the Security Lead
Testing	Sign-in tested every 90 days and after every CA change; result recorded

5. Test plan (What-If tool and sign-in logs)

ID	Persona	App	Scenario	Policies	Expected result
T01	Sarah Chen (Physician)	HVMC Electronic Health Record	Hospital-managed laptop, US, Authenticator MFA	CA003, CA005	Allow after MFA; session 8 h
T02	Sarah Chen (Physician)	HVMC Electronic Health Record	Personal laptop at home, US	CA005, CA006	Blocked (device not compliant) - CA006 limits session if CA005 still report-only
T03	Grace Nguyen (Reception)	HVMC Appointment Scheduling	Front-desk PC, US, MFA	CA003	Allow after MFA
T04	Any user	Exchange Online via IMAP client	Legacy authentication	CA001	Blocked
T05	Sabitha S Karanavar (Global Admin)	Azure portal	Password + SMS code	CA002, CA004	Blocked until a phishing-resistant method (FIDO2/passkey) is used
T06	Contractor (SG-Contractors-*)	HVMC VPN Portal	MFA, US	CA007, CA008	Allow; MFA every sign-in; no persistent session
T07	Contractor (SG-Contractors-*)	HVMC Electronic Health Record	Any	CA007	Blocked (app not in contract)
T08	Any user	Any app	Sign-in from outside the US	CA009	Blocked
T09	Any user	Any app	Device-code flow on a second device	CA010	Blocked
T10	Any user	Register security info	From outside the US without MFA	CA011	MFA required (blocked without it)
T11	Any user	Any app	Leaked credentials (user risk high)	CA012	MFA + secure password change
T12	Break-glass account	Azure portal	FIDO2 key, emergency	Excluded from all	Allow; Sentinel alert fires on every use
T13	Carlos Diaz (terminated contractor)	Any app	Account disabled (JML-203)	n/a	Blocked before CA: account disabled, sessions revoked

6. Rollout plan

Phase	Action	Exit criterion
0 · Prepare	Start the free 30-day Entra ID P2 trial; create the break-glass accounts and group, the US named location; register passkeys for admins	Break-glass sign-in tested
1 · Report-only (14 days)	`deploy_ca.py --apply` creates all 13 policies in report-only; review the CA insights and sign-in logs daily	No unexpected "would block" results for normal work
2 · Pilot ring	Enable CA001–CA004, CA010, CA011 for the IT group	One week without helpdesk issues
3 · Everyone	Enable the baseline for all users; **turn security defaults OFF** at the same moment (they cannot coexist with CA)	All test cases T01–T13 pass
4 · Clinical and contractors	Enable CA005–CA009 once devices are enrolled (Intune); then risk policies CA012–CA013	Monthly review of CA insights

7. Complementary tenant settings (free, no CA licence needed)

Setting	Today	Recommended	Risk
User consent to apps	Allowed	Only for verified publishers and low-risk permissions; admin-consent workflow for the rest	R08
Users can register applications	Yes	No — only Application Administrators	R08
Guest invitations	Anyone	Only admins and the Guest Inviter role	R08
Global Administrators	1	2 named admins + 2 break-glass, others use least-privileged roles	R04